

EIP Core API - Tenant Onboarding + Bootstrap Implementation Report

Date: 2026-01-19

Scope

- Backend-only (Fastify + Postgres). No frontend.
- Realm namespaces: /api/public, /api/eip, /api/edi, /api/portal (stub).
- Security guards preserved: requireSession, requireCsrf, requireIntegration, requireRealm, requireStepUp.
- Bootstrap stage restriction enforced.

Delivered Changes

- Migration 0037_tenant_onboarding.sql: tenant_request table, tenant status_code, onboarding permissions.
- Public endpoints:
 - POST /api/public/tenant-requests
 - GET /api/public/tenant-requests/status
- Admin endpoints:
 - GET /api/eip/admin/tenant-requests
 - POST /api/eip/admin/tenant-requests/:id/approve
 - POST /api/eip/admin/tenant-requests/:id/reject
- Bootstrap endpoints:
 - POST /api/eip/bootstrap/consume
 - POST /api/eip/bootstrap/password
 - POST /api/eip/bootstrap/totp/enroll
 - POST /api/eip/bootstrap/totp/confirm
 - POST /api/eip/bootstrap/device/trust
 - POST /api/eip/bootstrap/complete
- Email integration for dev/SMTP (token delivery).
- Rate limits and CORS applied to public/bootstrap routes.
- Config fail-closed on missing secrets (API_KEY_PEPPER, BOOTSTRAP_TOKEN_PEPPER, TOTP_SECRET_KEY).
- Redaction + logging script for onboarding happy-path.

Security Posture

- No regressions to session/cookie/CSRF/device/step-up/RBAC.
- Bootstrap sessions restricted to bootstrap routes + whoami/logout.
- Step-up enforced on R2 actions.
- Tokens and secrets never logged; redaction in test script.
- Storage: bootstrap token is hashed + single-use + TTL.

Testing Evidence (curl)

- Public tenant request -> ok.
- Admin OTP request/verify -> ok.
- Admin list requests -> ok.
- Approve request -> ok (token returned in dev).
- Bootstrap consume -> ok (bootstrap session established).

- Bootstrap password -> ok.
- Bootstrap TOTP enroll -> ok.
- Bootstrap TOTP confirm -> ok.
- Bootstrap device trust -> ok.
- Bootstrap complete -> 204, session cleared.
- whoami after complete -> 401.

Remaining Work / Gaps

- Portal realm endpoints not implemented.
- Automated tests not present.
- Formal email verification for applicants not implemented.
- Consider standardizing schema validation for all routes.

Files

- db/migrations/0037_tenant_onboarding.sql
- src/routes/tenant_requests_public.js
- src/routes/tenant_requests_admin.js
- src/routes/bootstrap.js
- src/server.js
- src/config.js
- scripts/onboarding_happy_path.sh